# Staffline Portal

## Rule book for QA

Roles, permissions, data scope and business rules, with the checks QA should run for each role.

Version 1.6 · 27 October 2026 · demo / pilot build (no backend)
Source of truth: `test/qa/role_rules_test.dart`, `docs/decisions.md` and `lib/core/permissions/`.

# Contents

1. How to use this book
2. Test accounts and setup
3. Portal-wide rules
4. Roles at a glance
5. Permission matrix
6. Page access by role
7. Role guides: Owner, HR Admin, Branch Manager, Attendance Manager, Leave Approver, Employee
8. Business rules by module
9. Defects found and fixed in this audit
10. Known limitations and items not built
11. Reporting a defect

# 1. How to use this book

This book states what each role in the portal may see and do. Every rule has an ID (for example **G-04** or **LV-03**). Quote the ID in a defect report so developers know which rule was broken.

- **Section 3** holds the rules that apply on every page.
- **Sections 4–6** say who can open what. Section 6 is the same table the automated test `role_rules_test.dart` checks, so a failure there is a real defect.
- **Section 7** has one guide per role, each with a checklist. Run the checklist for each role before every release.
- **Section 8** holds business rules by module (attendance, leave, holidays and so on).
- Anything in **Section 10** is a known limitation. Do not report it as a defect.

**Important:** this build has no backend. The app hides what a role may not use, but that is not a security boundary. Before real data is used, the server must enforce every rule in this book.

# 2. Test accounts and setup

All accounts belong to the demo organization **Meridian Textiles** (branches: Ahmedabad HQ, Surat, Vadodara, Rajkot depot (inactive)). The demo accounts are listed on the welcome page in demo builds.

| Sign in with | Person | Role | Scope | Two-step |
|---|---|---|---|---|
| ankit@meridiantex.in | Ankit Patel | Owner | Whole organization (also HR Admin of Patel Dyes; a deactivated membership at Sabarmati Retail) | Yes |
| hetal.s@meridiantex.in | Hetal Shah | HR Admin | Whole organization | Yes |
| jignesh.p@meridiantex.in | Jignesh Parmar | Branch Manager | Surat | Yes |
| mitesh.r@meridiantex.in | Mitesh Rana | Attendance Manager | Surat, Vadodara | Yes |
| aarav.b@meridiantex.in | Aarav Bhatt | Leave Approver | His direct reports | No |
| EMP-0229 | Isha Rathod | Employee | Own records (Surat) | No |
| admin@staffline.app | Staffline Platform Admin | Platform super admin | Statistics about all organizations; no organization records | Yes |

| Item | Value |
|---|---|
| Password (all accounts) | `Staffline@2026` |
| Two-step code (authenticator) | `482913` |
| Wrong codes before lock-out | 3, then sign-in is locked for 15 minutes |
| Demo "now" | Data is seeded relative to today. Screenshots and tests use Wed 14 Oct 2026, 14:10 (Asia/Kolkata). |
| Data resets | On every page reload. Nothing is saved on a server. |

**Platforms to test:** web (Chrome, Safari, Edge), macOS and iOS builds. Screen sizes from 320 px phone to 1920 px desktop. Text size up to 200%. Keyboard only.

# 3. Portal-wide rules

| ID | Rule | What must be true |
|---|---|---|
| G-01 | **Sign-in** | Members sign in with work email or employee ID plus password. Owner, HR Admin, Branch Manager and Attendance Manager must also enter a two-step code. A member of several organizations picks one; a deactivated membership cannot be opened. |
| G-02 | **Home page** | After sign-in each role lands on its own home (section 4). If the member was trying to open a page, they go there instead, if they are allowed to. |
| G-03 | **Menu = permission** | A menu item appears only when the role may view that module. A hidden item is a refused item. |
| G-04 | **Access denied** | Opening a page by URL that the role may not use shows "Access denied". It never shows the page, even briefly. |
| G-05 | **Data scope** | Every list, count, chart, report and export contains only records inside the member's scope: organization, assigned branches, own team, or own records. |
| G-06 | **Out-of-scope record** | A link to a person, branch or record outside scope shows a "not found" page ("This person isn't here", "This branch doesn't exist"). It does not say the record exists. |
| G-07 | **"All" in filters** | "All branches" in a filter means all branches the member can see, not the whole organization. |
| G-08 | **Buttons follow permissions** | Create, edit, approve, export and import buttons appear only when the role has that action on the module. Read-only roles see no edit controls. |
| G-09 | **Exports** | Every export needs view + export on its module (and the reports export right for reports). Rows are limited to the member's scope. Mobile number and personal email also need the restricted-fields right and organization scope. Every export and download is written to the audit log. |
| G-10 | **No self-approval** | Nobody approves or decides their own leave request or attendance correction. Such steps go to HR. |
| G-11 | **Masking** | Contact details, IDs, dates of birth and IP addresses are masked when shown or exported. Only the owner can reveal a value, must give a reason, and the reveal is logged. |
| G-12 | **Audit** | Every change (employees, attendance, leave, holidays, schedules, organization, branches, roles, invitations, settings, reports) records who, what, when, scope, reason and before/after. Entries cannot be edited or deleted by anyone. |
| G-13 | **Confirm it's you** | Saving a role or security settings asks for the password again. The re-check is logged. |
| G-14 | **Live permission changes** | When the owner changes someone's role, that person's menu, buttons and open pages update at once; a page they lose redirects to Access denied. |
| G-15 | **Sign-out** | Sign-out always returns to the welcome page. The next person to sign in never sees the previous person's page. |
| G-16 | **Notifications** | Nobody is notified about their own action. Notifications never include passwords, attachments or restricted fields. |
| G-18 | **Platform privacy** | The platform super admin sees only counts and organizations' business details (name, ID, industry, city/state, size, sign-up date). No person's name, email, phone or record appears anywhere in the platform area, and the super admin cannot open organization pages. |
| G-19 | **Downloads and uploads** | Every Template, Export and Download button saves a file that opens in Excel or as CSV — in the browser to Downloads, in the apps through a Save dialog. "Saved..." appears only after saving; cancelling shows nothing; a failure says what went wrong. Downloaded templates upload back without remapping columns. Upload buttons open the file picker on web, macOS, iOS and Android. |
| G-17 | **Responsive and accessible** | Every page works from 320 to 1920 px wide with no sideways page scroll (wide tables scroll inside their box), at 200% text, and by keyboard (Tab order, Enter submits, Escape closes dialogs, visible focus ring). |

# 4. Roles at a glance

| Role | Data scope | Lands on | Menu |
|---|---|---|---|
| **Owner** | Whole organization | Overview (setup home until employees exist) | Overview, Organization, Branches, Employees, Attendance, Leave Management, Holidays & Calendar, Roles & Permissions, Reports & Analytics, Notifications, Settings, Audit Log. Plus a BRANCHES group while any branch setup is below 100%. |
| **HR Admin** | Whole organization | Overview | Same as owner except Roles & Permissions. |
| **Branch Manager** | Assigned branches | Branch dashboard | Branch dashboard, Employees, Attendance exceptions, Leave approvals, Holidays, Branch reports. |
| **Attendance Manager** | Assigned branches | Attendance overview | Attendance overview, Records, Missing punches, Corrections, Monthly summary, Attendance exports. |
| **Leave Approver** | Own team (direct reports) | Approvals | ME: Home, Attendance, Leave, Holidays, Profile. MY TEAM: Approvals. |
| **Employee** | Own records | Home | Home, Attendance, Leave, Holidays, Profile (bottom tabs on phones, sidebar from 768 px). |

Owner, HR Admin, Leave Approver and Employee are locked system roles. Branch Manager and Attendance Manager are editable seeded roles. The owner can create custom roles that "work like" a system role: the base role sets the menu and home page, and its access sets what it may do. Owner-only rights cannot be given to another role.

**How access is set (D-79).** The owner edits a role in plain words: "Whose information can they see?" (Everyone / Chosen branches / Their team / Only themselves) and, for each area (People, Attendance, Leave…), one level — **No access · Can view · Can edit · Full control** — plus switches for special abilities such as "Approve or reject leave" or "Download attendance". "Fine-tune…" shows every ability of an area; "Show detailed table" shows the full permission table. An "In plain words" panel always lists what the role can and can't do. Roles are shown as cards; "Compare roles" puts all roles side by side; "Create role" starts from a copy of an existing role or from scratch.

# 5. Permission matrix

Actions: V view · C create · E edit · D deactivate · A approve · R correct · X export. "All" means every action.

| Module | Owner | HR Admin | Branch Mgr | Attendance Mgr | Leave Approver | Employee |
|---|---|---|---|---|---|---|
| Organization & branches | All | V | V | — | — | — |
| Employees | All | All | V C E X | — | — | — |
| Employee fields | All | V E | — | — | — | — |
| Attendance | All | All | V A R X | V A R X | — | — |
| Leave | All | All | V C A X | — | V A | — |
| Holidays | All | All | V | — | — | — |
| Settings | All | V E | — | — | — | — |
| Roles & permissions | All | — | — | — | — | — |
| Dashboard & reports | All | V X | V X | — | — | — |
| Import & export | All | All | — | — | — | — |
| Audit log | All | V X | — | — | — | — |

Every member, whatever the role, has the self-service pages: Home (punch in/out), My attendance, My leave, My holidays, My profile and My notifications. A member without an employee record (for example the owner) sees "No employee record" there.

**Owner-only:** Organization edit, owner profile, creating or editing branches and branch setup, Roles & Permissions (roles, people & access, new role), Security settings, Data & export settings, revealing masked values. The last owner cannot lose the Owner role.

# 6. Page access by role

✓ = the page opens. × = "Access denied". This table is checked by the automated test; if a page behaves differently, it is a defect against **G-04**.

| Page | URL | Own | HR | BM | AM | LA | Emp |
|---|---|---|---|---|---|---|---|
| Overview | `/overview` | ✓ | ✓ | ✓ | × | × | × |
| Organization profile | `/organization` | ✓ | ✓ | ✓ | × | × | × |
| Owner profile | `/organization/owner-profile` | ✓ | × | × | × | × | × |
| Branches | `/branches` | ✓ | ✓ | ✓ | × | × | × |
| Create branch | `/branches/new` | ✓ | × | × | × | × | × |
| Edit branch | `/branches/{id}/edit` | ✓ | × | × | × | × | × |
| Employees | `/employees` | ✓ | ✓ | ✓ | × | × | × |
| Add employee | `/employees/new` | ✓ | ✓ | ✓ | × | × | × |
| Import employees | `/employees/import` | ✓ | ✓ | × | × | × | × |
| Employee fields | `/settings/employee-fields` | ✓ | ✓ | × | × | × | × |
| Branch dashboard | `/branch-dashboard` | ✓ | ✓ | ✓ | × | × | × |
| Attendance overview | `/attendance` | ✓ | ✓ | ✓ | ✓ | × | × |
| Attendance records | `/attendance/records` | ✓ | ✓ | ✓ | ✓ | × | × |
| Attendance exports | `/attendance/exports` | ✓ | ✓ | ✓ | ✓ | × | × |
| Face check (selfie reviews) | `/attendance/face-check` | ✓ | ✓ | ✓ | ✓ | × | × |
| Leave approvals | `/leave` | ✓ | ✓ | ✓ | × | ✓ | × |
| Leave balances | `/leave/balances` | ✓ | ✓ | ✓ | × | ✓ | × |
| Leave types | `/leave/types` | ✓ | ✓ | × | × | × | × |
| Leave policy | `/leave/policy` | ✓ | ✓ | × | × | × | × |
| Holiday calendar | `/holidays` | ✓ | ✓ | ✓ | × | × | × |
| Add holiday | `/holidays/new` | ✓ | ✓ | × | × | × | × |
| Import holidays | `/holidays/import` | ✓ | ✓ | × | × | × | × |
| Roles | `/roles` | ✓ | × | × | × | × | × |
| People & access | `/roles/people` | ✓ | × | × | × | × | × |
| New role | `/roles/new` | ✓ | × | × | × | × | × |
| Invitations | `/roles/invitations` | ✓ | ✓ | ✓ | × | × | × |
| Report center | `/reports` | ✓ | ✓ | ✓ | × | × | × |
| Export history | `/reports/exports` | ✓ | ✓ | ✓ | × | × | × |
| Settings | `/settings` | ✓ | ✓ | × | × | × | × |
| Attendance policy | `/settings/attendance` | ✓ | ✓ | × | × | × | × |
| Security settings | `/settings/security` | ✓ | × | × | × | × | × |
| Data & export settings | `/settings/data` | ✓ | × | × | × | × | × |
| Audit log | `/audit-log` | ✓ | ✓ | × | × | × | × |
| Approvals (team) | `/team/approvals` | ✓ | ✓ | ✓ | × | ✓ | × |
| Self-service pages | `/home, /my/...` | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ |
| Face for attendance (own) | `/my/profile/face` | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ |
| Platform overview (super admin only) | `/platform` | × | × | × | × | × | × |

# 7. Role guides

## 7.1 Owner (ankit@meridiantex.in)

Runs the organization. Has every permission. The only role that edits the organization, branches, roles and security.

### Can do

- Register, create the organization, complete owner profile and branch setup (setup home shows progress per branch).
- Create, edit and deactivate branches. A branch with employees cannot be made inactive until they are moved.
- Everything HR Admin can do (7.2).
- Roles & Permissions: create a custom role (or duplicate a system one), edit seeded custom roles, change a person's role and branches, review high-impact changes.
- Security settings (two-step policy, passwords, lock-out, invitation lifetime) and Data & export settings.
- Reveal a masked value with a reason.
- Switch organization (Patel Dyes as HR Admin).

### Cannot do

- Edit locked system roles (they can only be duplicated).
- Remove the Owner role from the last owner.
- Approve their own leave (no employee record in demo data anyway).

### QA checklist

| # | Steps | Expected result |
|---|---|---|
| 1 | Sign in with password and code 482913, choose Meridian Textiles. | Lands on Overview. Choose organization lists 3 memberships; Sabarmati is deactivated and cannot be opened. |
| 2 | Create a branch, then open its setup. | Branch appears in Branches and in the sidebar BRANCHES group with a percentage. |
| 3 | Roles → Branch Manager → Edit → in the Leave card switch off "Approve or reject leave" → Review & save, enter a reason. | Asked for the password again; the audit log shows the change, the reason and the re-check. |
| 4 | Sign in as Jignesh → Leave approvals → open a request. | The request is visible but there is no Approve button. |
| 5 | Settings → Security: change invitation days; open Invitations. | Expiry dates follow the new value. |
| 6 | Audit log → open an entry with a masked value → Reveal. | A reason is required; the reveal itself is logged. |

## 7.2 HR Admin (hetal.s@meridiantex.in)

Manages people, attendance, leave and holidays for the whole organization. Sees the organization and branches but cannot change them.

### Can do

- Employees: add, edit, import (with "update existing"), export, deactivate, terminate and archive, manage custom employee fields.
- Invitations: send, resend, fix the email, revoke.
- Attendance: all pages; correct punches; approve corrections (including those a manager made for their own report).
- Leave: approve any pending step except own requests; adjust balances with a reason; edit leave types and policy.
- Holidays: add, edit, import and export holidays; schedules.
- Settings: attendance policy, work schedules, notifications, branding, employee fields.
- Reports and audit log: view and export.

### Cannot do

- Edit organization or branch details (view only, D-63).
- Open Roles & Permissions, Security or Data & export settings.
- Decide their own leave request or the same request twice.

### QA checklist

| # | Steps | Expected result |
|---|---|---|
| 1 | Sign in (two-step). | Lands on Overview. No Roles & Permissions in the menu. |
| 2 | Open /roles, /settings/security, /settings/data. | Access denied each time. |
| 3 | Branches → Surat. | Details visible; no Edit or Create branch button. |
| 4 | Employees → Import a file with a duplicate ID. | Row is flagged; "Update existing" needs a tick to confirm. |
| 5 | Leave balances → Adjust a balance without a reason. | Save is blocked until a reason is entered. |
| 6 | Approvals page. | Says "You approve leave for everyone in the organization."; own requests cannot be decided. |
| 7 | Reports → export the employee roster. | File downloads; it appears in Export history and the audit log. |
| 8 | Settings → Employee fields: set Mobile number to Required and Designation to Hidden; save. Open Add employee and save empty. | Designation is not on the form; the error list includes "Mobile number — Enter a mobile number." The audit log shows both changes. |
| 9 | Owner: give Branch Manager "Employee fields: View"; sign in as Jignesh → Employees → Columns → Manage employee fields. | Page opens with "View only"; no Save or New field buttons. |

## 7.3 Branch Manager (jignesh.p@meridiantex.in, Surat)

Runs one or more branches. Everything they see is limited to their assigned branches.

### Can do

- Branch dashboard for Surat.
- Employees in Surat: view, add (branch fixed to Surat), edit, export. Contact details are masked.
- Invitations for Surat people only.
- Attendance for Surat: records, missing punches, corrections, monthly summary, exports.
- Leave: decide any request from Surat (not their own); view requests and balances; export.
- Holidays: view only. Reports: Surat only, with export.

### Cannot do

- See or open other branches, their people, invitations, attendance or leave.
- Import employees, edit employee fields, change settings, open the audit log.
- Edit holidays (no Add or Export buttons).
- Approve their own leave (it goes to HR).

### QA checklist

| # | Steps | Expected result |
|---|---|---|
| 1 | Sign in (two-step). | Lands on Branch dashboard for Surat. |
| 2 | Employees. | Branch filter locked to "Branch: Surat"; only Surat people listed. |
| 3 | Open /employees/e-1 (an Ahmedabad person). | "This person isn't here". |
| 4 | Open /branches. | Only Surat listed. |
| 5 | Open /branches/b-vad. | "This branch doesn't exist". |
| 6 | Invitations. | Only Surat people (e.g. Chirag Vaghela); no Ahmedabad invites. |

| # | Steps | Expected result |
|---|---|---|
| 7 | Holidays → list. | No Add holiday, Import / export or Export buttons. |
| 8 | Add employee. | Branch is Surat and cannot be changed to another branch. |
| 9 | Open /employees/import, /settings, /audit-log. | Access denied. |
| 10 | Attendance → Face check → "Don't accept…" a punch without a reason, then with one. | Blocked without a reason; with one, the punch stops counting and Isha is notified. |

## 7.4 Attendance Manager (mitesh.r@meridiantex.in, Surat + Vadodara)

Keeps attendance correct for assigned branches. Has no other module.

### Can do

- View attendance overview, daily records, missing punches, monthly summary for Surat and Vadodara.
- Correct punches (adds a correction; the original punch is kept).
- Approve employees' correction requests.
- Export attendance.

### Cannot do

- Open Employees, Leave, Holidays, Reports, Settings or Audit log.
- See Ahmedabad attendance.
- Approve a correction they made themselves.

### QA checklist

| # | Steps | Expected result |
|---|---|---|
| 1 | Sign in (two-step). | Lands on Attendance overview; figures cover Surat + Vadodara only. |
| 2 | Records → filter "All branches". | Only Surat and Vadodara people appear. |
| 3 | Missing punches → correct a punch with a reason. | Correction saved; history shows the original and the correction, with name and reason. |
| 4 | Open /employees, /leave, /reports. | Access denied. |
| 5 | Attendance exports → Download. | File has only Surat/Vadodara rows; logged in audit. |

## 7.5 Leave Approver (aarav.b@meridiantex.in)

An employee who also approves leave for their direct reports.

### Can do

- Everything an Employee can do (7.6) for themselves.
- Approvals: approve, reject (reason of at least 3 characters) or request changes on steps assigned to them.
- View leave requests and balances of their own team.

### Cannot do

- See leave of people who don't report to them.
- Export leave or balances (no Export buttons).
- Approve their own leave.
- Open Employees, Attendance admin pages, Holidays admin, Reports, Settings.

### QA checklist

| # | Steps | Expected result |
|---|---|---|
| 1 | Sign in (no two-step). | Lands on Approvals; ME and MY TEAM sections in the menu. |

| # | Steps | Expected result |
|---|---|---|
| 2 | Approvals → Reject with reason "no". | Blocked: reason needs at least 3 characters. |
| 3 | Approvals → Request changes on Isha's request. | Isha sees the note and can change dates or withdraw. |
| 4 | Open /leave/requests and /leave/balances. | Only own team; no Export button. |
| 5 | Apply for own leave. | Goes to his manager or HR, never to himself. |
| 6 | Open /employees, /attendance. | Access denied. |

## 7.6 Employee (EMP-0229, Isha Rathod)

Uses self-service only. Sees nothing about other people except team counts shown on their own requests.

### Can do

- Punch in and punch out from Home (a second punch-in while one is open is refused).
- My attendance: month view, day detail, request a correction within 3 days.
- My leave: balances, apply (dates, half day, reason), change or withdraw a pending request, cancel approved leave before it starts (if policy allows), history.
- My holidays, My profile (edit allowed fields, photo), My notifications.

### Cannot do

- Open any admin page (Overview, Employees, Attendance admin, Leave admin, Reports, Settings…).
- Request a correction for a day older than 3 days.
- Edit HR-only profile fields (branch, manager, joining date…).

### QA checklist

| # | Steps | Expected result |
|---|---|---|
| 1 | Sign in with EMP-0229 (no two-step). | Lands on Home with punch button. |
| 2 | (Selfie on for Surat) Home → Set up → tick consent → take 3 photos → Send. | Status "Waiting for HR approval". Hetal sees it in Face check and approves. |
| 3 | (Selfie on, set up) Punch out with demo answer "Match", then "No match". | "Face verified." the first time; the second is saved and goes to Face check for Jignesh. |
| 4 | Punch in, then punch out. | Times appear after the app confirms them; status updates. |
| 5 | Open a day older than 3 days → Request correction. | Not allowed; day shows as overdue. |
| 6 | Apply for casual leave for 3 days spanning a holiday. | Holiday and weekly off are not counted; balance after is shown. |
| 7 | Open /overview, /employees, /leave. | Access denied. |
| 8 | Sign out, sign in as Aarav, approve; sign back in as Isha. | Request shows Approved and balance is reduced. |

## 7.7 Platform super admin (admin@staffline.app)

Staffline's own operator. Sees statistics about every registered organization — how many organizations, branches and employees, and how much they use the portal — never personal data.

### Can do

- Sign in (two-step always) and land on Platform overview.
- See KPIs: organizations, active branches, employees, accounts in use, active today.
- See charts, each a different kind: daily active employees (line), new organizations per month (columns), share of employees (100% bar), organization status (donut), feature use (ring gauges), by industry (dot plot), by state (shaded tiles). On an organization: activity calendar (heatmap), accounts in use (ring) and branches (bullet bars: active today out of employees).

- Search and filter the organization list (status: Active, Setting up, No activity in 7 days) and open one organization: usage tiles, daily activity chart, features in use, branch counts.

### Cannot do

- See any person's name, email, phone or record — owners included.
- Open any organization page (Overview, Employees, Attendance…); every such link returns to the platform.
- Change anything: the platform area is read-only. Support sessions, billing and suspend are not built.

### QA checklist

| # | Steps | Expected result |
|---|---|---|
| 1 | Sign in with admin@staffline.app, password and code 482913. | Lands on /platform. Sidebar says "Signed in as platform admin · 2-step verified". |
| 2 | Check the KPIs and the Organizations table. | 8 organizations; Coastal Craft Exports shows "Setting up"; numbers in the table add up to the KPIs. |
| 3 | Search every page and table for a person's name, email or phone (e.g. Ankit Patel, Isha Rathod, any "@"). | Nothing found. Branch and organization names, cities and states only. |
| 4 | Open Kaveri Foods. | Branches Peenya and Hosur with counts; "Selfie punches: On at 1 branch". |
| 5 | Type /employees or /overview in the address bar. | Returns to /platform. |
| 6 | Sign in as Ankit (owner) and open /platform. | Access denied. |
| 7 | Phone width and 200% text. | No overflow; Sign out is in the top bar. |

# 8. Business rules by module

## Employees

| ID | Rule |
|---|---|
| EM-01 | One set of checks applies to the add form, the edit form and the import. A work email is required only when an invitation is sent. |
| EM-02 | Employee ID must be unique. Import matches duplicates by employee ID. |
| EM-13 | Mobile: 10 digits starting 6–9; "+91", "91" or "0" in front, spaces, dashes and brackets are fine. "12345", "5825012345" and foreign numbers are refused with: "Enter a 10-digit mobile number starting with 6, 7, 8 or 9, with or without +91." |
| EM-14 | First and last name: letters (any script), spaces, dots, apostrophes and hyphens, up to 50 — no digits. Designation: 2–60 characters with letters. |
| EM-15 | Personal email must be valid and different from the work email. Emergency contact must contain a name and a valid 10-digit phone number, and not the employee's own mobile. |
| EM-16 | Date of birth: not in the future, at least 18 on the joining date, not over 80. Joining date: at most 6 months ahead. |
| EM-17 | The same rules apply to the add form, edit form, import and the employee's own profile. Branch and organization phones accept landlines with the area code (e.g. 079 4000 2210); PIN codes have 6 digits and don't start with 0. |
| EM-03 | Import never guesses dates: if a date could be read two ways, the person must choose DD/MM/YYYY or MM/DD/YYYY first. Close matches for branch or manager are warnings, never silent fixes. |
| EM-04 | "Update existing" in import needs edit permission and a tick to confirm. It changes only mapped, non-empty columns and never branch, manager or joining date. |
| EM-05 | Someone who still manages people cannot be deactivated or terminated until their reports are reassigned. |
| EM-06 | Terminate and archive asks for an effective date and reason. Terminated people leave the default list and head counts but keep their history (filter by Terminated). |
| EM-07 | Branch head counts come from employee records (inactive included, terminated excluded). |
| EM-09 | Settings → Employee fields → Built-in fields: each field is Required, Optional or Hidden for the whole organization. Locked as required: Employee ID, first name, last name, branch, joining date, employment type, shift, reporting manager. Work email can't be hidden; probation and weekly off can't be required. |
| EM-10 | The add form, edit form and import follow these rules: hidden fields disappear (saved values are kept), required fields block saving with "Enter ...", the import template and column list leave hidden fields out, and required columns must be mapped. |
| EM-11 | Personal email, date of birth and emergency contact are only required from people who can see restricted fields. In an import, required fields the file can't carry show as warnings. |
| EM-12 | Who can change the rules is set in Roles & Permissions → "Employee fields" (View = read-only page, Edit = change). Owner always, HR Admin by default. Changes are in the audit log. |
| EM-08 | Invitation links last the number of days set in Security settings (default 7). People set their own password; passwords are never shown or emailed. |

## Attendance

| ID | Rule |
|---|---|
| AT-01 | Original punches are never edited. Corrections are added on top and count only when approved. |
| AT-02 | A correction made by the employee's own manager waits for a second person (HR). Nobody approves their own correction. |
| AT-03 | Employees can request a correction within 3 days of the day, one open request per day. Missing punches older than 3 days are "overdue". |
| AT-04 | Times are stored in UTC and shown in the branch time zone (default Asia/Kolkata). |
| AT-05 | A session belongs to the day its shift started (night shift: punches before noon count for the previous day). A punch-out more than 20 hours after the punch-in starts a new session with a missing punch-in. |
| AT-06 | Worked time = closed sessions minus breaks. Expected time = shift length minus the 60-minute allowed break. |

| ID | Rule |
|---|---|
| AT-07 | Status order: missing punch → half day (late more than 120 min, or worked half the expected time or less) → left early (30 min) → short shift (more than 1 h short) → late (after 10 min grace) → present. Defaults; each branch can change them in Attendance policy. |
| AT-08 | Approved full-day leave shows the day as On leave, not absent. If the person punches on a leave day, the punches win. |
| AT-09 | A punch is shown only after it is confirmed. A retry can't record it twice. A second punch-in while a session is open is refused. |

## Selfie attendance (face check)

| ID | Rule |
|---|---|
| FC-01 | Owner or HR Admin switches "Selfie with each punch" on per branch in Settings → Attendance policy. The change is in the audit log. |
| FC-02 | In a selfie branch, Punch in / Punch out opens the front camera. Only a live photo can be used; there is no gallery upload. Cancelling the camera records nothing. |
| FC-03 | Before set-up the employee must read what is collected and tick consent. Nothing can be photographed without the tick. Three guided photos: straight, slightly left, slightly right. |
| FC-04 | Set-ups are approved or rejected (reason of at least 3 characters) by HR Admin or the Owner only, never by the person themselves. |
| FC-05 | A punch whose face is verified shows "Face verified." Any other result (didn't match, no face found, face not set up) is still saved and shows "...your manager will check the selfie". |
| FC-06 | Punches to review appear in Attendance → Face check for roles with attendance approve rights, limited to their scope. Nobody reviews their own punch. |
| FC-07 | Accepting keeps the punch. "Don't accept" needs a reason; the punch then stops counting, the day shows the missing punch, and the employee is notified and can request a correction. |
| FC-08 | HR can let a person punch without a selfie (reason required) and can undo it. |
| FC-09 | The employee can delete their face data at any time from My profile → Face for attendance. |
| FC-10 | Notifications: managers and HR when a punch needs review; HR when a set-up waits; the employee when a set-up or review is decided. All actions are audited. |

## Leave

| ID | Rule |
|---|---|
| LV-01 | Balance = granted (prorated or accrued monthly) + carried + adjustments − approved − pending. Balances are calculated, never typed in. |
| LV-02 | Request days are counted from the work calendar: weekly offs and holidays are skipped unless the leave type counts them. A holiday added later gives the day back automatically. |
| LV-03 | Step 1 approver is the reporting manager (HR when the branch approves centrally or there is no manager). An optional step 2 comes from the most specific policy route: leave type › branch › default. |
| LV-04 | Who decides: owner and HR any pending step except their own; a branch manager any request from their branches; a leave approver only steps assigned to them. |
| LV-05 | Rejecting needs a reason of at least 3 characters. "Request changes" sends it back with a note; the employee changes dates (earlier dates kept as "Changed from") or withdraws. |
| LV-06 | Approved leave can be cancelled only before it starts, and only if the policy allows it. |
| LV-07 | Backdated requests are allowed up to the policy limit (at most 30 days). Blackout dates block requests. |
| LV-08 | Balance adjustments need a reason and are audited. |
| LV-09 | Optional holidays are taken with the "Optional holiday" leave type, limited per year by the policy (default 1). |

## Holidays and schedules

| ID | Rule |
|---|---|
| HO-01 | Holidays can apply to all branches, selected branches, or be optional; a single day or a range of up to 14 days. |
| HO-02 | Past holidays cannot be added, edited or deleted (attendance already used them). |
| HO-03 | Schedules are dated assignments at four levels; the most specific in effect wins: employee › shift group › branch › organization. A person's own weekly off beats group and branch. |
| HO-04 | Schedule changes cannot start in the past. Attendance and leave read the same work calendar. |

## Roles, security and settings

| ID | Rule |
|---|---|
| RS-01 | System roles (Owner, HR Admin, Leave Approver, Employee) are read-only; they can be duplicated. |
| RS-02 | Promoting someone to HR Admin or Owner is a high-impact change and shows a review step. |
| RS-03 | Changing someone's role also updates their employee record so leave routing stays right. |
| RS-04 | Defaults: minimum password 10 characters (8–64 allowed), lock-out 15 minutes, reset links valid 30 minutes and usable once, invitations 7 days. |
| RS-05 | Logos and photos: PNG or JPG only, up to 2 MB, checked by file content (a renamed file is refused). SVG is not accepted. |

## Reports, notifications and audit

| ID | Rule |
|---|---|
| RP-01 | Reports only include branches and fields the role can access. The audit-log report is Owner and HR Admin only. |
| RP-02 | Every export appears in Export history. Download links expire (7 days in this build). |
| RP-03 | Notifications follow the preference matrix in Settings (event × employee / manager / HR × in-app / email). Emails are queued, not sent, in this build. |
| RP-04 | Audit entries are append-only and chained with a checksum; the log shows whether the chain verifies. |

# 9. Defects found and fixed in this audit (21 Oct 2026)

Each role was signed in and every page of the app (66 URLs) was opened. No page crashed. The guards matched the permission matrix. These scope and permission defects were found and fixed:

| # | Defect | Rule | Fix |
|---|---|---|---|
| 1 | Branch manager saw all four branches (with head counts) in Branches and could open another branch's page by URL. | G-05, G-06 | Branches and branch pages show only assigned branches; others show "doesn't exist". |
| 2 | Branch manager saw invitations for other branches and could resend or revoke them. | G-05 | Invitations list only people in the member's scope. |
| 3 | Leave approver saw Export on Leave requests and Export balances, without export permission. | G-08, G-09 | Buttons need leave export permission. |
| 4 | Branch manager (view-only holidays) saw Export on the holiday list. | G-08 | Button needs holidays export permission. |
| 5 | HR's Approvals page said "You approve leave for the 0 people who report to you" above 8 requests. | — | Text now matches the scope ("everyone in the organization", "people in your branches"). |
| 6 | Overview opened by a branch manager said "All branches". | G-07 | Now says "All my branches". |

Automated: `test/qa/role_rules_test.dart` (14 tests) checks the page-access table for all six roles and each fix above. Full suite: 736 tests passed (27 Oct 2026), including sweeps that press every control on every page for all seven accounts.

# 10. Known limitations and items not built

Do not log these as defects.

| Area | Status |
|---|---|
| Backend | None. Data is in memory and resets on reload. Permissions are enforced only in the app. |
| Sign-in | One demo password and a fixed two-step code. Password length, lock-out, idle timeout and session length are saved but not enforced. |
| Email | Invitations, resets and notifications go to an in-app outbox, not real email. |
| Punches | Use the device clock; no location or kiosk check. |
| Selfie matching | Simulated in the demo: demo builds show a "Match / No match" choice under the punch button. Real face matching and liveness checks come with the backend. No camera on macOS. |
| Platform administration | Statistics-only super admin is built (7.7). Support sessions, plans & billing, suspend and owner account help (boards S97–S98) are not. |
| Not designed | Team calendar, global search results, break start/end buttons, kiosk mode (setting only), two-step setup and device list in My profile (status only). |
| Simplified | Work schedules edited through branch hours; branding and language saved but not applied; leave attachments, encashment and carried-days expiry not built; schedule assignments can be added but not edited; holiday import fixed by re-uploading; no drag-and-drop upload; India (+91) phone numbers only. |
| Cosmetic | At 200% text some long labels end in "…" (full text in tooltip). On phones a message can cover the bottom action bar for 4 seconds. |
| Demo tools | Demo accounts list and design gallery are visible to everyone in demo builds; hidden in a production build (SHOW_DEV_TOOLS=false). |

# 11. Reporting a defect

- **Title:** role + page + what went wrong, e.g. "Branch Manager: Ahmedabad people visible in Leave balances".
- **Rule broken:** the rule ID from this book (e.g. G-05, LV-04).
- **Account and steps:** which demo account, screen size, browser, and numbered steps from sign-in.
- **Expected vs actual**, with a screenshot.

| Severity | Meaning | Examples |
|---|---|---|
| Critical | Data outside the role's scope is visible, or a refused action can be done. | G-04, G-05, G-09, G-10 broken |
| High | A main flow can't be completed. | Can't apply for leave, punch, approve |
| Medium | A rule is wrong but there is a workaround. | Wrong day count, wrong status label |
| Low | Cosmetic or wording. | Misaligned text, unclear message |